Sentinel SOC — Product Review Board

Eighth Review · Post-Remediation Due Diligence

Three independent frontier models. Eight dossiers. Every load-bearing claim verified against source — including three that did not survive.

Board: Claude Opus 4.8 (Anthropic) · Codex GPT-5.6-terra (OpenAI) · Antigravity / Gemini 3.1 Pro (Google) **Method:** 3 rounds — independent review, adversarial cross-examination, final verdict **Run:** 2026-07-25T06:10Z → 06:20Z · 8 of 9 seats returned · ~98 KB of transcript **Subject:** `sentinel_soc` — after eight remediation passes (v7 closed 10 findings; v8 recovered two zero-byte modules) **Baseline:** Seventh Review — Overall 38, Investment-readiness 19, NO on launch/commercial/Series A, 2–1 NO on seed

> ***Quorum note.*** *The Codex seat filed its Round 1 dossier and Round 2 cross-examination in full — the two rounds carrying its substantive analysis — then exhausted its account's Codex quota before Round 3. Its final position in this report is its* ***Round 2 revised scores****, which it stated explicitly, together with the verdict it stated in prose. No Codex number, vote, or opinion in this report has been extrapolated or invented; every place where its formal Round 3 filing is missing is marked. See §2.*

> ***Scope note.*** *This is a diligence opinion on a codebase and a business, not personalised investment advice. No seat is a licensed financial adviser. Nothing here is a recommendation to buy, sell, or hold any security. No secret found in the repository is reproduced, and no finding recommends disabling a safety gate, an auth path, or a human-approval step.*

Contents

Sentinel SOC — Product Review Board

Eighth Review · Post-Remediation Due Diligence

1. Executive Summary

The single finding that defines this review
Three claims from the remediation record that are false
What is genuinely strong
The verdict

2. Council Composition & Method

The seats
Seat availability — two issues worth recording
Run telemetry

3. Consensus Scorecard

Reading the spread
Calibration: the seats' predictions about each other

4. Final Verdict & Votes

The single biggest risk, per seat
Where the board disagrees

5. What Changed Since the Seventh Review

Credited as genuinely closed
Reopened or newly opened
What did not move at all

6. Verified Findings Register

7. Claims That Did Not Survive Cross-Examination

8. Component-by-Component Review

8.1 Lifecycle, retry and execution fencing — the epicentre
8.2 Attestation, evidence and ledger semantics
8.3 Dashboard, analyst UX and XSS
8.4 Auth, identity and tenant isolation
8.5 Storage, queue and scale
8.6 Detection and protect mode
8.7 The mutation harness — answering the brief's dare

9. Market Intelligence & Competitive Position

10. Gap Analysis

11. Feature Discovery

12. Technical Architecture Review

13. UX & User Journey Review

14. Security Audit

OWASP Agentic (ASI) Top 10 coverage — verified, not claimed
Other security findings

15. Performance & Scalability Audit

16. AI Capability Audit

17. Hidden Opportunities & Patent-Worthy Ideas

Ignored markets
Patent-worthy

18. Investment Review

Would the named funds invest?
What a diligence team would find in the first week
Investment score: 11 / 100

19. Business Model & Monetization

Recommended packaging
Growth loops and network effects
Initial customer segment
The honest outcome distribution

20. Risk Register

21. Launch Readiness Checklist

Can this product launch today? NO — unanimous.

22. Prioritized Improvement Backlog

The board's top 6, in order

23. Multi-Year Product Roadmap

24. Final Council Consensus

Consensus scores
The final recommendation
What would have to be true for this to be a $1B+ company

25. Actionable Next Steps

26. References & Appendices

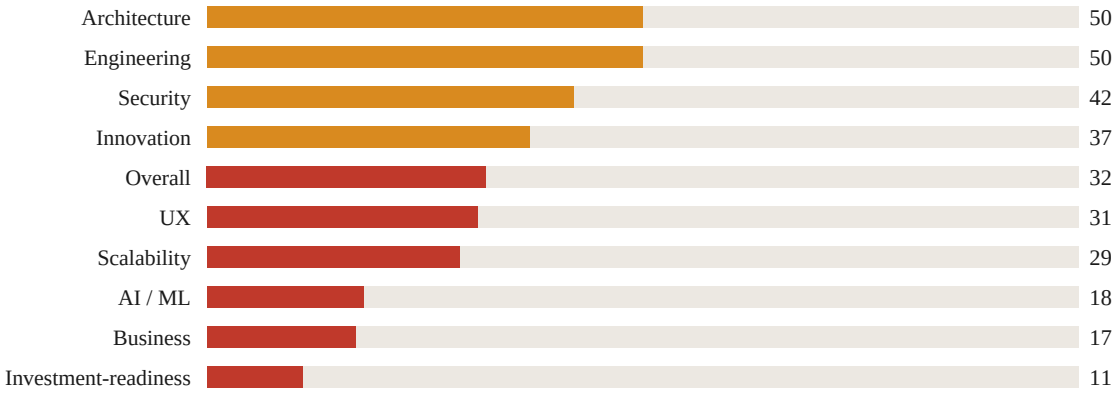
A. Transcript index
B. Source documents
C. Method limitations — stated, not hidden
D. Reproducing this review

1. Executive Summary

Two more remediation passes have landed since the last board. The consensus **Overall score moved 38 → 32**, and **Investment-readiness moved 19 → 11**. Both went *down*. Engineering fell from 71 to 50 and Security from 51 to 42.

This is the first review in this codebase's history where the scores moved backwards, and the reason is not that the code got worse. It is that this board found what the previous seven did not: **the pattern relocated again, and this time it landed in the core value path.**

Consensus Scores — Eighth Review (0-100, mean of three seats)



The single finding that defines this review

v8's flagship fix — the "resumable stage dispatcher," built specifically so a retry would *resume* rather than replay — **relocated the codebase's signature failure a sixth time, directly into the product's core promise.**

On the exact transient-RPC retry the dispatcher exists to survive, `process()` rebuilds `Context` with `evidence=None` and skips already-durable stages *by rank without rehydrating them* (`api/pipeline.py:569-587`). The attestation stage then receives no evidence, `publish_attestation` returns `"Skipped"` (`agents/attestation_agent.py:137-144`), and the incident nonetheless transitions to `COMPLETED` with `is_anchored=false` (`app/core/repository.py:627-640`).

A product whose entire pitch is tamper-evident, non-repudiable attestation can **silently emit an evidence-less "completed" incident** — and it does so precisely when something has gone wrong, which is the only moment the attestation matters.

The Claude seat found this. It is also the seat that wrote every remediation pass, including this one, and it filed the finding against its own work and led with it. Codex and Antigravity each verified it independently against source and both moved their scores down as a result. Codex's own words: *"the claimed fix therefore moves the bug from replayed transitions to a successful-looking no-op attestation."*

Three claims from the remediation record that are false

The board verified these against source. All three were stated as closed:

Claim	Reality	Evidence
"`esc()` escapes every server-supplied value"	False. `JSON.stringify(inc.intel.external_data)` goes into `innerHTML` unescaped; `transaction_hash` is injected into an `href`/`title` unvalidated; the CSP explicitly permits inline script, so it is not a compensating control. **Live stored XSS in the analyst console.**	`dashboard/index.html:1344-1352`, `:1270-1274`, `:7-24`
"No unfenced transition helper exists"	False. `_terminalise()` calls `repository.fail()` with no epoch; `fail()` defaults `epoch=None`; the fence is skipped entirely when epoch is None. The module docstring at `pipeline.py:45-50` warns against exactly this helper — and then defines it.	`api/pipeline.py:614-617` → `app/core/repository.py:646-662`, `:289`
"Resume *resumes* instead of replaying"	Partly true and dangerously incomplete. It eliminates illegal backward transitions; it does not preserve the artifacts the resumed stages consume.	`api/pipeline.py:552-588`

The pattern is consistent and it is the most important thing in this report: **a fix closes the demonstrated sink, and the claim generalises to the whole class while a sibling sink stays open.** Sixth recurrence.

What is genuinely strong

The board was not uniformly negative, and the strengths are real:

- **Fail-closed provenance holds.** `verify_package` requires an out-of-band `trusted_signer` and never falls back to the package's own `signer_address` (`app/attestation/ledger.py:223-236`, `:358-398`). No seat could construct a `True` for evidence Sentinel never signed. Codex, the harshest seat on engineering, called this "real progress."
- **The Merkle crypto is textbook.** Second-preimage prefixes, promote-don't-duplicate for odd nodes (avoiding CVE-2012-2459), geometry checks before hashing (`app/attestation/merkle.py:26-28`, `:168-169`, `:214-234`). An auditor really can verify offline.
- **Identity-bound leaves** commit to `tenant_id + incident_id + body hash`, so relabelling a genuine proof onto another incident breaks the signature (`merkle.py:67-82`).
- **Redaction-preserving chains** — GDPR erasure that keeps proofs valid, with `REDACTED` reported distinctly from tampering (`app/storage/db.py:983-1017`, `ledger.py:276-308`).
- **The LLM is out of the control path by design.** Priority is a pure function; the model is advisory and its failure is non-fatal (`api/pipeline.py:219-259`). Genuinely good security engineering.
- **RLS now defaults ON** — a real correction of the prior "proven but defaults-off" trap (`app/storage/db.py:352-370`). Codex specifically refuted Antigravity's stale claim here.

The verdict

Unanimous NO on launching, piloting, commercial viability and Series A. On seed the board is 3–0 NO on the product, with Claude noting it would entertain a pre-seed check on *the team* with a contractual pivot attached.

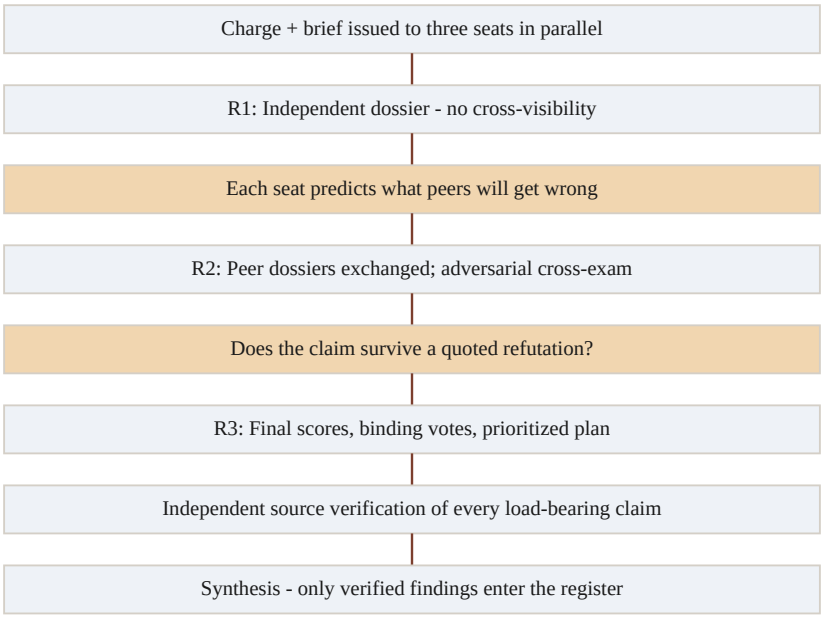
The board's answer to the question the brief posed — *is the constraint still engineering, or is it commercial?* — is that **it is now both, and neither is the one the team has been working on.** Detection has not moved in eight passes (AUC 0.763, ECE 0.48). There are zero customers, zero production runtime, and no Kubernetes cluster has ever run this code. And the codebase is **not under version control**: v8 opened with two load-bearing modules truncated to zero bytes, `.pyc` recompiled over the truncation, unrecoverable.

Claude's framing, which the other two seats endorsed: *"This is excellent systems-engineering practice in search of a business. I would fund the team, not the company."*

---

2. Council Composition & Method

Review Method — three rounds, independence enforced by construction



The seats

Seat	Vendor	Model	Access	Sandbox
Claude Opus 4.8	Anthropic	`claude-opus-4-8`	Ambient CLI login	Read-only (`Read,Glob,Grep`)
Codex GPT-5.6-terra	OpenAI	`gpt-5.6-terra`	Ambient CLI login	`exec` read-only sandbox
Antigravity	Google	Gemini 3.1 Pro (`agentapi --model=pro`)	OAuth, no API key	Read-only by prompt, not policy

Independence is enforced structurally, not by instruction: Round 1 prompts contain no peer content at all. Each seat was also asked to predict what the others would get wrong — a calibration probe that turned out to be informative (§3).

Seat availability — two issues worth recording

The Codex seat was dead on arrival and was repaired before the run. Every call returned HTTP 400 `"The 'gpt-5.6-sol' model is not supported when using Codex with a ChatGPT account"` — an entitlement error that presents as an auth error. Auth was in fact healthy. The cause was that the global `~/.codex/config.toml` pinned a model slug absent from the account's server-advertised catalog. The seat now pins `gpt-5.6-terra` in `council/seats.py` rather than inheriting global config, so the council no longer depends on a user-level file it does not own.

The Codex seat then exhausted its plan quota during Round 3. It completed R1 (17,984 chars) and R2 (15,673 chars) and failed at R3 with `"You've hit your usage limit."` The quota is account-wide — cheaper

model slugs were tested and are equally blocked — and resets 2026-08-24.

Consequences for this report, stated plainly:

- Codex's **independent dossier and cross-examination are complete and are used in full.**
- Codex's final scores are its **Round 2 revised scores**, which it stated explicitly and labelled as revisions.
- Codex **never stated an OVERALL integer** in any round. Its cell is empty everywhere in this report; no value has been imputed.
- Codex **never filed the machine-readable VOTES block.** Its verdict is quoted from its Round 2 prose, where it wrote: *"Therefore: **no launch, no seed, no Series A.**"*

Antigravity also deviated from the required Round 3 format: it filed scores but no OVERALL integer and no VOTES block. Its positions below are likewise drawn from its prose, marked as such.

Only the Claude seat filed a fully conformant Round 3. This is a limitation of the run and it is disclosed rather than smoothed over.

Run telemetry

Round	Claude	Codex	Antigravity
R1 — independent dossier	ok · 236s · 17.4 KB	ok · 198s · 18.0 KB	ok · 92s · 10.8 KB
R2 — cross-examination	ok · 217s · 10.6 KB	ok · 234s · 15.7 KB	ok · 194s · 8.9 KB
R3 — final verdict	ok · 84s · 10.4 KB	**FAILED — quota**	ok · 109s · 7.2 KB

3. Consensus Scorecard

Every number below was stated by the seat that owns the cell. Nothing is imputed.

Lens	Claude (R3)	Codex (R2 final)	Antigravity (R3)	Mean	Spread	v7 board	Δ
Engineering	46	43	60	**50**	17	71	–**21**
Architecture	48	38	65	**50**	27	57	–**7**
Security	41	40	45	**42**	5	51	–**9**
Innovation	37	35	40	**37**	5	43	–**6**
UX	31	28	35	**31**	7	24	**+7**
Scalability	26	20	40	**29**	20	40	–**11**
AI / ML	20	17	17	**18**	3	22	–**4**
Business	17	20	15	**17**	5	22	–**5**
Investment-readiness	12	10	10	**11**	2	19	–**8**
Overall	**33**	*not stated*	*not stated*	**32** †	—	38	–**6**

† Claude is the only seat that stated an Overall integer (33). The **32** is the synthesizer's unweighted mean of the nine lens means, computed and labelled as derived. The two agree to within a point, which is weak corroboration, not a second opinion.

Reading the spread

The tightest agreement is on the things that matter most commercially. Investment-readiness spans 2 points (12/10/10). AI/ML spans 3 (20/17/17). Business spans 5 (17/20/15). Three independent models from rival vendors, given no visibility into each other, converged to within noise on the conclusion that this is not a fundable business and that its AI does not work.

The widest spread is Architecture (27 points) and it is a real disagreement, not noise. Antigravity scored 65 on the strength of the fencing and outbox primitives; Codex scored 38 because it treats rank-only resume and O(tenants) scheduling as *architecture-level* failures rather than bugs. Codex's position is better evidenced and Claude's 48 sits between them.

Engineering fell 21 points. This is the headline movement and it decomposes cleanly: Antigravity opened at 85 in Round 1 and cut to 60 after reading its peers; Codex cut 50 → 43; Claude cut 60 → 55 → 46. Every seat moved the same direction after seeing verified evidence, which is what a functioning adversarial process looks like.

UX rose 7 points — the only lens that improved. This is not praise. It reflects that the v7 authenticated console (OIDC PKCE + CSRF) genuinely landed; the score remains in the low 30s because the manual-instrumentation adoption tax is untouched and the "MONITORING: LIVE" indicator is a UI flag over a stale, unauthenticated collector (§13).

Calibration: the seats' predictions about each other

Each seat predicted, in Round 1, what its peers would get wrong. Scoring those predictions is a useful check on whether this board was reasoning or performing:

Prediction	Made by	Outcome
"They will credit the resumable dispatcher as a clean close of C-1"	Claude	**Correct.** Antigravity did exactly this ("eliminating transient failures as a cause for data loss") and retracted in R2.
"They will give engineering remediation commercial credit"	Codex	**Wrong — and to the board's credit.** No seat moved Business or Investment up.
"They will conflate a clean codebase with a viable business"	Antigravity	**Wrong.** All three seats separated the two explicitly.
"They will over-weight the blockchain / Base Sepolia debate"	Claude	**Half right.** Antigravity led with it as a "fundamental commercial disqualifier"; Codex corrected the implementation claim as overbroad.

4. Final Verdict & Votes

Question	Claude	Codex	Antigravity	Board
Can launch today?	**NO**	**NO** [1]	**NO** [1]	**NO (3–0)**
Safe to run a real pilot?	**NO**	*not stated*	*not stated*	**NO (1–0)**
Viable commercial product?	**NO**	**NO** [1]	**NO** [1]	**NO (3–0)**
Fundable at seed?	**NO**	**NO** [1]	**NO** [1]	**NO (3–0)**
Fundable at Series A?	**NO**	**NO** [1]	**NO** [1]	**NO (3–0)**
Has a defensible moat?	**NO**	**NO** [1]	**NO** [1]	**NO (3–0)**
Category-defining potential?	**NO**	*not stated*	*not stated*	**NO (1–0)**

[1] Stated in prose, not in the required vote format. Codex R2: *"Therefore: no launch, no seed, no Series A."* Antigravity R3: *"Verdict: NO (Do Not Invest)… Not Ready… This is not a Series A company."* On the moat, all three describe the attestation wedge as a *feature or wedge, not yet a moat*; Antigravity adds that it *could become* one if the team pivots to an open standard.

The single biggest risk, per seat

- **Claude:** *"Retry silently produces evidence-less 'COMPLETED' attestations — the core value path fails invisibly."*
- **Codex:** *"The flagship recovery path can silently convert an attestation outage into a completed-but-unattested incident… exactly under failure — the moment an enterprise buyer needs it."*
- **Antigravity:** *"Critical flaws continue to be relocated rather than eliminated… the complete lack of a version control floor indicates unacceptable operational discipline for a security company."*

All three name the same failure. That is the strongest signal in this review.

Where the board disagrees

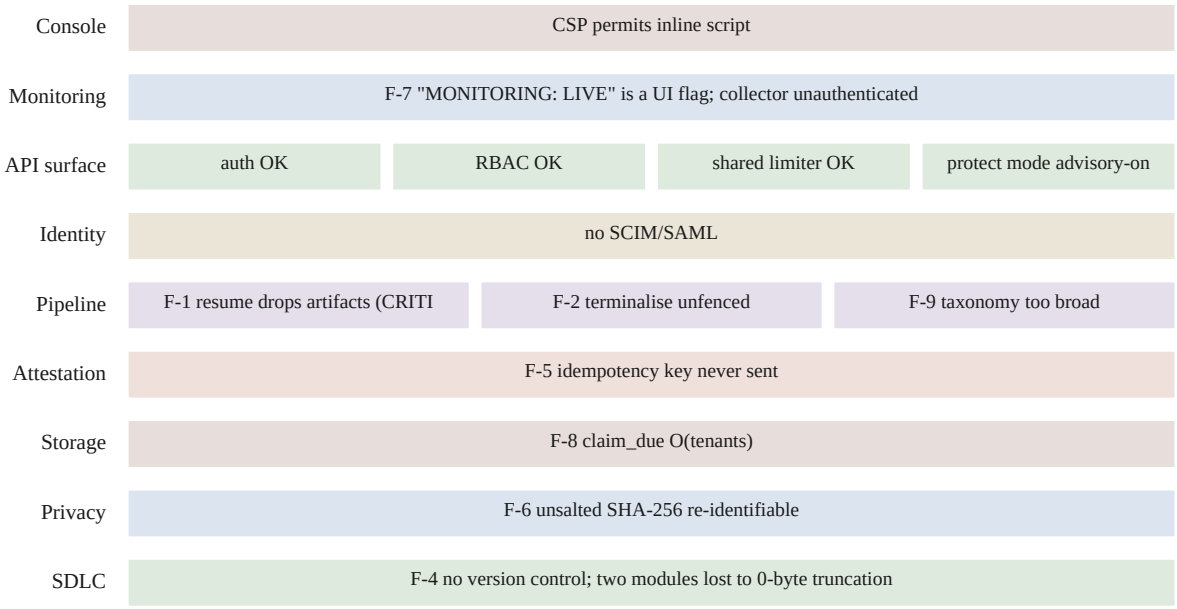
One material disagreement, and it is about severity, not existence. Codex and Antigravity rate the unfenced `_terminalise` write **Critical**. Claude rates it **High**, arguing that terminal errors are deterministic and both the stale and the new worker resume from the same durable rank, so outcomes converge and blast radius is bounded — the violated *invariant* matters more than the realized harm.

The synthesis adopts **High**, for a reason neither side stated: the convergence argument is sound, but it is a property of *today's* terminal error set, not a guarantee. It should be treated as High-with-a-structural-fix, which is what the remediation plan in §21 specifies.

Claude also dissents mildly on seed, being willing to entertain a pre-seed check on the team with a contractual pivot away from "generic AI SOC." Neither peer would. This does not change the board position on the product.

5. What Changed Since the Seventh Review

Where the verified defects sit in the stack (Eighth Review)



Credited as genuinely closed

The v7 pass closed ten findings and this board did not reopen most of them. Specifically verified as holding:

- **C-3 authenticated relabelling** — v2 identity-bound manifests bind tenant + incident; relabelling breaks the signature. Verified by Claude and Codex independently.
- **C-4 K8s egress** — strict-parse manifest tests are real; no seat challenged it.
- **H-2 OIDC tenant collapse** — `tenant_from_claims` fails closed; JWT failure does not downgrade to API-key auth (`api/rbac.py:104-149`).
- **M-2 redaction tombstone** — idempotent, `EvidenceRedacted`, verified distinct from tampering.
- **RLS default flip** — now defaults ON. Codex explicitly refuted Antigravity's stale "defaults off" claim with source.

Reopened or newly opened

#	Finding	Status
C-1	Retry non-resumable	**Reopened, worse.** Backward transitions fixed; artifact loss introduced.
C-2	Fence dropped	**Reopened in the error path.** `_terminalise` is the unfenced helper the docstring warns about.
—	Stored XSS	**Never fully closed.** The fix was sink-specific; the claim was class-wide.
H-4	Side effects before fenced transition	**Partially closed.** Outbox claim is fenced; the idempotency key is generated, stored, and never passed to the gateway.

What did not move at all

Detection: **AUC 0.763, ECE 0.48 — unchanged across eight passes.** Customers: zero. Production runtime: zero. Distribution: none. Positioning: unchanged, for the third board running that has recommended changing it.

6. Verified Findings Register

Only findings that at least one seat verified against source, and that survived cross-examination, appear here. Findings refuted during debate are in §7.

ID	Finding	Severity	Evidence	Seats
F-1	Resume rebuilds `Context` with `evidence=None` and skips durable stages by rank without rehydrating; attestation returns `Skipped`; incident still reaches `COMPLETED` unanchored	**Critical**	`api/pipeline.py:569-587`; `agents/attestation_agent.py:137-144`; `app/core/repository.py:627-640`	3/3
F-2	`_terminalise` calls `fail()` without epoch; `fail()` defaults `epoch=None`; fence skipped entirely	**High** [2]	`api/pipeline.py:614-617`; `app/core/repository.py:646-662`, `:289`	3/3
F-3	Stored XSS live in analyst console: `external_data` via `innerHTML`, `transaction_hash` in `href`/`title`; CSP permits inline script	**Critical**	`dashboard/index.html:1344-1352`, `:1270-1274`, `:7-24`	3/3
F-4	Repository not under version control; two load-bearing modules found at 0 bytes, `.pyc` recompiled over truncation, unrecoverable	**Critical**	`council/REMEDIATION_V8.md` §1	2/3
F-5	Attestation idempotency key generated and stored but never passed to the gateway; no `assert_execution()` immediately before publish	**High**	`api/pipeline.py:405-409`; `app/core/repository.py:251`	2/3
F-6	Redaction correlation hash is unsalted SHA-256; low-entropy bodies are re-identifiable by dictionary attack	**High**	`app/attestation/redaction.py:53-69`	3/3

ID	Finding	Severity	Evidence	Seats
F-7	"MONITORING: LIVE" is a tenant flag only; legacy `ContinuousMonitor` hardcodes unauthenticated `localhost:8000/ingest-event`, ignores HTTP status, marks events seen regardless of acceptance	**High**	`api/main.py:623-628`; `app/monitoring/continuous_monitor.py:13-23`, `:50-61`, `:95-108`	1/3
F-8	`claim_due()` iterates tenants serially with a transaction each — O(tenants) per poll	**Medium** [3]	`app/core/dlq.py:150-196`; `app/queue/durable_queue.py:200-230`	3/3
F-9	`TERMINAL_ERRORS` includes `ValueError`/`TypeError`/`KeyError`; transient I/O failures routinely surface as these and are recorded permanently `FAILED`	**High**	`api/pipeline.py:91-98`, `:601-606`	1/3
F-10	Detection unchanged: AUC 0.763 two-fold, ECE 0.484; classifier shadow-only by default	**Critical (business)**	`README.md:111-142`; `app/monitoring/rules.py:46-53`	3/3
F-11	Protect mode returns `enforced: false`; no inline interception, no kill switch	**High**	`api/main.py:801-813`; `README.md:174-182`	3/3
F-12	Mutation harness is real but narrow — no probe encodes the terminalisation-fence invariant, so it could not catch F-2	**Medium**	`tests/mutation_support.py:50-99`	2/3

[2] Codex and Antigravity rated Critical; Claude rated High on bounded-blast-radius reasoning. Synthesis adopts High. See §4. [3] Medium today, High at scale. All three seats agree on the shape.

7. Claims That Did Not Survive Cross-Examination

Recording these matters as much as recording the findings: it is the evidence that the board was adversarial rather than additive, and it prevents a future reader from acting on a wrong line number.

Claim	Made by	Refuted by	Resolution
"`claim_attestation()` can overwrite a `delivering` claim rather than reject a different epoch"	Codex	**Claude and Antigravity, independently**	**Wrong mechanism.** `claim_attestation` calls `_locked_incident(…, epoch)`, which raises `FenceLost` on mismatch (`repository.py:556`, `:289`); `complete_attestation` re-checks (`:617`). Both claim and receipt are fenced. Codex's *conclusion* (H-4 not fully closed) survives via a different path — the un-passed idempotency key, F-5.
"RLS defaults off by default"	Antigravity	Codex	**Stale.** Postgres RLS now defaults enabled; disabling requires an explicit false-valued override (`app/storage/db.py:352-370`). The residual issue is that SQLite has no RLS.
"SQLite is the primary datastore and queue"	Antigravity	Claude and Codex	**Wrong.** `app/storage/db.py:449-474` is a dual-backend adapter; live mode *requires* Postgres and refuses multi-replica SQLite (`app/core/config.py:155-173`; `app/storage/engine.py:161-177`). Antigravity's Scalability 65 rested on this and was cut to 40.
"Testnet blockchain is a fundamental commercial disqualifier"	Antigravity	Codex	**Directionally fair, implementation claim overbroad.** Live mode rejects in-process keys and requires a remote KMS/HSM signer; the code does not force Sepolia. The real blocker is more precise: *no verified production chain/contract deployment exists while the UI implies one.*

Claim	Made by	Refuted by	Resolution
"Cryptographic kill switch — complexity: Low"	Antigravity	Claude	**Mis-priced.** Protect mode is `enforced: false` with no inline interception point; "invalidating downstream API access" requires a data plane that does not exist. This is the single hardest item on the roadmap, not a low-effort one.
"`esc()` escapes every server-supplied value"	The remediation record	Codex, confirmed by Claude and Antigravity	**False.** See F-3. Claude, who wrote the claim, retracted it explicitly.

8. Component-by-Component Review

8.1 Lifecycle, retry and execution fencing — the epicentre

Strongest claim made: v8 made the pipeline resumable and fencing structurally complete (Antigravity, Engineering 85).

Resolved position — Critical. Resume is *rank-based, not artifact-based*. Durable state is loaded once; neither evidence nor report inputs are rehydrated; all stages at or below the current rank are skipped. An RPC failure during attestation permanently produces an evidence-less, unanchored "completed" incident — the exact failure class v8 claimed to fix.

Two structural claims from the remediation record were tested and one failed:

- *"No unfenced transition helper exists"* — **false**, `_terminalise` is one (F-2).
- *"Every side effect goes through the repository outbox"* — **holds**, but the outbox's own idempotency key never reaches the gateway (F-5).

Solution: hydrate each skipped stage's durable artifact, *or* build `Context` from durable evidence/report/decision rows; **and** make `COMPLETED` structurally unreachable when `is_anchored=false` by splitting `ATTESTED` / `ATTESTATION_UNAVAILABLE`. Add fault-injection tests at the report and attestation boundaries that require an anchored receipt or an explicit loud terminal state. **Effort:** 2–3 days. **Tradeoff:** one or more extra reads per retry — negligible beside correctness.

There is a deeper design note the board surfaced. The dispatcher's "one SELECT per incident" optimisation is justified by the execution fence making the worker the single writer. That reasoning is sound *only while* every side-effecting stage asserts the fence on every write — which is true today and is exactly the standing invariant that one new call site breaks. F-2 is that call site, arriving one pass after the invariant was declared structural.

8.2 Attestation, evidence and ledger semantics

The cryptography is materially stronger than the operational semantics around it.

Strong: fail-closed `verify_package`; identity-bound v2 manifests; redaction that replaces the mutable body with an idempotent tombstone while retaining its commitment; `REDACTED` reported distinctly from tampering.

Weak: any missing evidence *or* unverified agent identity yields `Skipped` — and that receipt still transitions to `COMPLETED`. `COMPLETED` **conflates "workflow finished" with "attested,"** which destroys buyer confidence in the primary claim. Codex's fix is the right one: split `COMPLETED_UNATTESTED`, `ATTESTED`, `ATTESTATION_UNAVAILABLE`, and let policy decide which is acceptable per tenant.

The blockchain should be optional periodic anchoring, never the customer's primary audit store. The board is unanimous that **the moat is portable, independently verifiable evidence — not Base Sepolia.** Per-event on-chain writes are the one thing every seat said never to copy.

8.3 Dashboard, analyst UX and XSS

The fix was **sink-specific; the claim was class-wide.** Known incident and reasoning sinks escape correctly, and the report renderer's move to escaped `<pre>` text is strictly safer than the old `marked.parse(esc(...))`. But `external_data` and `transaction_hash` are open, and the existing test covers only selected named sinks

(`tests/test_dashboard_xss.py:90-140`).

Risk: a compromised enrichment provider or signer gateway becomes a same-origin attack path into an admin console. **Solution:** DOM APIs and `textContent` instead of templated HTML; validate transaction hashes as hex before generating a fixed explorer URL; nonce-based CSP; and a browser-level taint test over **every network-derived field**, not a named list. **Effort:** 2–4 days.

8.4 Auth, identity and tenant isolation

The primitives are credible: JWT failure does not downgrade to API-key auth; API keys default to least-privilege ingest roles; the SDK can sign agent events and unsigned events are deliberately non-attestable. RLS is strong on Postgres with `FORCE ROW LEVEL SECURITY` and transaction-local tenant context.

What is missing is *enterprise identity operations*: no SCIM, no SAML, no tenant-management UI, no group-to-role mapping, no agent-key rotation or revocation. **This architecture passes a technical review and fails procurement.** Medium for pilots; High before enterprise GA.

8.5 Storage, queue and scale

Not SQLite-bound — that claim was refuted. But global queue selection and DLQ claiming iterate every tenant, creating O(tenants) scans and transactions per poll. **Tenant count, not event volume, becomes the throughput and tail-latency bottleneck.**

Per-tenant hash-chain ordering (`prev_chain_hash`) is intrinsically serial, which caps per-tenant throughput by design. Worker threads run inside API pods — not a scalable worker plane.

Solution ordering matters here: shard queue ownership by tenant hash or add a privileged, audited scheduler path; graduate to Kafka/NATS **only after proving the Postgres queue's ceiling.** No seat could produce a single benchmark, because none exists.

8.6 Detection and protect mode

Strategically correct, commercially insufficient. Deterministic authority is good security engineering: attacker-influenced text cannot move priority. But it does not make Sentinel a prompt-injection detector, and detection is what the market buys.

Sentinel's default policy maps principally to **ASI01, ASI02, ASI03 and ASI09**. The board could not verify runtime controls for ASI04 (supply chain), ASI05 (code execution), ASI06 (memory poisoning), ASI07 (inter-agent comms), ASI08 (cascades) or ASI10 (rogue agents). **Roughly 4 of 10, against a product narrative that implies 10 of 10.**

8.7 The mutation harness — answering the brief's dare

The brief dared the board to write a mutation the harness would not catch. Claude answered it directly: **the harness would not catch the `fail(epoch=None)` mutation**, because no probe encodes "terminalisation is fenced." The harness genuinely loads a mutated module and requires a behavioural probe to fail — it is not substring theatre — but it proves only that *the guards it enumerates* are load-bearing. It says nothing about invariants no probe encodes.

That is a narrower guarantee than "the other fixes are trustworthy," which is what the remediation record leans on it for. F-2 is the proof: it is a real, verified invariant violation that sat inside a codebase with a working mutation harness.

---

9. Market Intelligence & Competitive Position

The category exists, is well funded, and **has already consolidated.**

Company	Status	Relevance to Sentinel
Lakera	→ Check Point (~$300M)	Runtime guardrails; free dev tier is the adoption model to borrow
Protect AI	→ Palo Alto Networks	Roadmap now answers to platform strategy — strands focused buyers
Prompt Security	→ SentinelOne	Same dynamic
Aim Security	→ Cato Networks	Same dynamic
Astrix Security	→ Cisco (~$400M)	**Non-human identity — Sentinel's exact wedge, now owned by Cisco**
Zenity, Noma ($100M B), WitnessAI, HiddenLayer, Straiker, Pillar, Lasso	Independent	Better funded than this team can bootstrap
Microsoft, Cisco, Palo Alto, Check Point, SentinelOne, Radware	Platform giants	Compete directly, with distribution

Where Sentinel is worse: detection (competitors ship tuned classifiers; Sentinel's is demoted shadow at 0.763), enterprise procurement, integrations, telemetry collection, SOC workflows, threat research, global support, and distribution — where it has none.

Where Sentinel is better — one axis only: offline-verifiable, identity-bound cryptographic evidence with fail-closed verification. **No incumbent leads with tamper-evident attestation an auditor can verify years later from a single file.** All three seats independently identified this as the only defensible wedge.

What to borrow: OTel-native instrumentation, policy-as-code, deployment templates, identity federation, red-team/eval workflows, and Lakera's free-developer-tier motion. **What never to copy:** platform bundling, black-box detection claims, and per-event blockchain logging.

Sentinel SWOT — Eighth Review board consensus

Strengths
- Fail-closed provenance verified - no seat found a keyless route to True
- Textbook Merkle crypto with identity-bound leaves; offline-verifiable by an auditor
- Redaction-preserving chains - lawful erasure with intact cryptographic commitment
- LLM deliberately outside the control path; deterministic authority is correct

Weaknesses
- Detection unmoved in eight passes (AUC 0.763, ECE 0.48) - the named value prop
- Sixth relocation, this time into the core value path; three "closed" claims false
- No version control; two load-bearing modules lost to silent truncation
- Zero customers, zero production runtime, no distribution, no pricing evidence

Opportunities
- Consolidation strands buyers who want neutrality acquirers structurally cannot offer
- Evidence passport as an interchange standard; auditors become the demand channel
- Regulated agent workflows (fintech, health, legal, BPO) with high-consequence delegation

Threats
- Astrix-to-Cisco means the identity wedge now has a giant owner
- A seventh relocation would end the codebase's remaining credibility
- Microsoft/OTel auto-instrumentation solves the adoption tax Sentinel has not

10. Gap Analysis

The real unsolved pains in this market, and whether Sentinel can credibly close them:

Market pain	Can Sentinel close it?	Assessment
Proving what an autonomous agent did, *after* evidence is lawfully redacted	**Yes — at the primitive level**	The redaction-preserving chain is genuinely novel and directly on target
Agent identity and non-repudiation (53% of MCP servers use static keys)	**Yes — at the primitive level**	Signature-recovered addresses; refuses to invent identities
Audit evidence that survives log destruction	**Yes**	Hash chain + optional anchor addresses this directly
Buyers stranded by consolidation wanting vendor neutrality	**Yes, commercially**	The clearest opening in the market; requires GTM, not code
Mapping a decision to identity + delegated authority + policy version + tool call + approval + outcome	**Partially**	The data model supports it; the product does not surface it
Detecting prompt injection / goal hijack / memory poisoning	**No**	AUC 0.763, ECE 0.48. This is the constraint
Preventing unsafe actions without blocking operations	**No**	Protect mode is `enforced: false`; no data plane exists
Near-zero-cost adoption	**No**	Manual per-call SDK wiring; no OTel auto-instrumentation

The diagnosis: Sentinel can close the *evidence* pains at the primitive level and cannot close the *detection* or *enforcement* pains at all. That is not a roadmap gap — it is a positioning instruction. The product is named and sold as the thing it cannot do, and it under-sells the thing it can.

---

11. Feature Discovery

Features no competitor currently offers, drawn from all three dossiers and de-duplicated. Ranked by the board's assessment of defensibility per unit of effort.

1. Portable evidence passport *(Claude)*

Problem: acquisition-orphaned buyers distrust vendor-locked audit logs. **Design:** signed, self-describing export plus a ~200-line standalone verifier shipped as free OSS. **Complexity:** Low — the crypto already produces offline-verifiable packages. **AI requirement:** none. **Business value:** turns the wedge into a distribution motion — auditors demand the verifier, buyers adopt to satisfy auditors. **Defensibility:** becomes a de-facto interchange format; network effects if auditors adopt it.

2. Delegation passport *(Codex)*

Problem: ASI03/ASI07 accountability across agent-to-agent hops. **Design:** bind user purpose, agent identity, delegated scopes, tool budget, expiry and approval chain into a signed capability that travels with the request. **Complexity:** High. **AI requirement:** none. **Defensibility:** a cross-vendor receipt graph is a data moat, not a feature.

3. Counterfactual control replay / policy-diff replay *(Codex + Claude, converged)*

Problem: "would this new policy have caught last month's incidents?" — and its inverse, "how many false blocks would it have caused?" **Design:** replay durable incident facts through a candidate `active_policy()`; quantify blocked actions, false blocks, latency and approval burden. The resumable state model already stores everything needed. **Complexity:** Medium-high. **AI requirement:** trace normalisation, not generative judgment. **Defensibility:** stickiness via accumulated incident corpus; makes security adoption *measurable*, which is how it gets budget.

4. Evidence-minimization compiler *(Codex)*

Problem: proving a claim to an auditor without exporting sensitive prompts. **Design:** compile raw tool calls into a receipt containing only the fields necessary for a specific audit claim, with selective disclosure. **Complexity:** High. **Defensibility:** the most patent-worthy item in this report (§17).

5. Cross-vendor notarization to a neutral transparency log *(Claude)*

Problem: nobody trusts a single vendor's "we saw nothing bad." **Design:** periodic Merkle-root anchoring to Sigstore/Rekor-style transparency logs or an RFC 3161 timestamping authority — **not a testnet**. **Complexity:** Low-medium. **Defensibility:** reframes the blockchain question from liability into differentiator.

6. Autonomy circuit breaker *(Codex)*

Problem: ASI08/ASI10 — cascading failures and rogue agents. **Design:** detect rapidly expanding tool scope, privilege, spend or agent fan-out; enforce progressive budgets before a cascade. **Complexity:** Medium-high. **AI requirement:** per-tenant anomaly baselines.

7. Prompt provenance quarantine *(Codex)*

Problem: ASI01/ASI06 — indirect injection through retrieval and memory. **Design:** taint-label untrusted context through retrieval, memory and inter-agent messages; prohibit it from influencing authority-bearing fields without corroboration. **Complexity:** High. **Note:** this is the only proposed feature that would meaningfully improve detection without a data flywheel.

8. Shadow agent discovery *(Antigravity)*

Problem: shadow AI deployments bypass governance entirely. **Design:** eBPF/network-level detection of calls to known LLM providers from unauthorized workloads. **Complexity:** Medium. **Value:** expands from monitoring into discovery and posture — and is a natural *land* motion for a product with no distribution.

---

12. Technical Architecture Review

Component	Assessment	Verdict
Frontend / console	OIDC PKCE + CSRF session; escaped `<pre>` report renderer; **two live XSS sinks**; CSP permits inline script; polls rather than streams	**Weak**
API surface	FastAPI; RBAC with least-privilege defaults; JWT failure does not downgrade to API key; shared DB rate limiter fixes per-pod multiplication	**Sound**
Auth / authz	OIDC rejects non-asymmetric algs, validates issuer/audience, tenant claim fails closed	**Sound**
Data model	Durable incident state, facts and audit trail committed together; evidence + ledger entry + transition share one transaction	**Strong**
Storage	Dual backend; live mode requires Postgres and refuses multi-replica SQLite; `FORCE ROW LEVEL SECURITY`, RLS default ON	**Sound**
Queue / workers	Durable DB queue with fencing; DLQ is a real state machine with exclusive claim and jittered backoff; **O(tenants) drain**; workers run inside API pods	**Weak at scale**
Pipeline orchestration	Resumable dispatcher over durable state — **and the location of the Critical finding**	**Broken on the retry path**
Attestation / ledger	Textbook Merkle; identity-bound leaves; fail-closed verification; chain-agnostic	**Strong**
Agent orchestration	LLM advisory-only, non-fatal on failure, cannot move priority	**Correct by design**
Detection / ML	Pickle-deserialized classifier; AUC 0.763; ECE 0.484; shadow by default; no adversarial robustness eval	**Non-functional as a product claim**
RAG / vector / knowledge graph	Not present. Lens does not apply — and its absence is correct for this product	**N/A**
Observability	structlog JSON, OpenTelemetry tracing, Prometheus endpoint wired; **no running collector, no dashboards, no OTLP export verified**	**Seams, not systems**
Testing	459 pass / 7 skip; real mutation harness; **no probe for the terminalisation invariant**; live tests unrunnable on this machine	**Good, with a proven blind spot**
CI/CD	Lint, blocking dependency audit, image scanning, live Postgres tests, schema fuzzing	**Strong**

Component	Assessment	Verdict
SDLC	**No version control.** Two modules lost to 0-byte truncation, unrecoverable	**Critical failure**
Deployment	Helm + K8s manifests, strict-parse tested; readiness vs liveness correct	**Sound, never executed**
Scalability	No broker, no multi-region, no autoscaling, **zero benchmarks**	**Unproven**
Secrets / keys	KMS/HSM signer preferred; in-process key rejected in live mode; **ECDSA recovery primitive unaudited**	**Sound, unaudited**

13. UX & User Journey Review

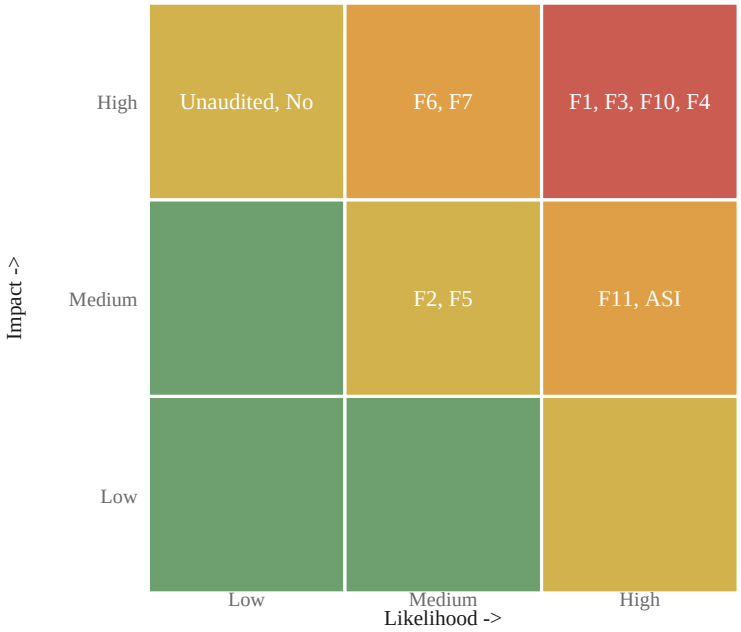
Walking the journey as a first-time buyer would:

Stage	Finding	Severity
Landing	Honest — "pre-production" is stated, not buried. Genuinely differentiating in this category	■
Onboarding	**Hard stop.** Manual per-call SDK instrumentation. No drop-in proxy, no OTel auto-instrumentation, no eBPF. This alone blocks pilots	■ Critical
Signup / auth	OIDC PKCE + CSRF works; **no SAML, no SCIM, no tenant-management UI** — fails enterprise procurement and offboarding	■ High
Dashboard	Polls rather than streams; **two live XSS sinks**; no grouping or correlation of identical attacks across agents → alert fatigue	■ Critical
Monitoring indicator	**"MONITORING: LIVE" is a tenant flag.** The route only writes the flag. The legacy collector hardcodes unauthenticated `localhost:8000`, ignores HTTP status, and marks events seen regardless of acceptance	■ Critical (trust)
AI interaction	Deterministic findings plus a clearly-labelled advisory second opinion — **actually clean, and the right design**	■
Reports	On a resumed incident, "Not available" everywhere — the user-visible face of F-1	■ Critical
Attestation status	UI says "Anchoring batch root" while the code records individual incidents. **Trust-damaging mismatch** in the one place trust is the product	■ High
Settings / policy	No policy simulation, no change approvals, no evidence-verification wizard	■ High
Notifications / errors	No approval-queue workflow; no clear distinction between "recorded," "sealed," "signed," and "externally anchored"	■ High
Help / support	Not assessed — no support surface exists to assess	—

The synthesis: the friction that kills adoption is **day-zero instrumentation**, not the dashboard. But the friction that kills *trust* is the cluster of places where the UI asserts something the code does not do — LIVE monitoring, batch anchoring, and a report that says "Not available" after a retry. For a product whose category is trustworthiness, these are not cosmetic.

14. Security Audit

Security Risk Heatmap — Eighth Review (Likelihood x Impact)



F1	Resume emits unanchored "COMPLETED" attestation
F3	Stored XSS live in analyst console
F10	Detection non-functional (AUC 0.763 / ECE 0.48)
F4	No version control; silent module truncation
F11	Protect mode advisory-only; no kill switch
ASI	coverage roughly 4 of 10 categories
F6	Unsalted correlation hash re-identifiable
F2	Terminalise bypasses execution fence
F5	Idempotency key never reaches gateway
F7	"MONITORING: LIVE" over unauthenticated collector
Unaudited	ECDSA recovery primitive
No	DAST; never deployed to a cluster

OWASP Agentic (ASI) Top 10 coverage — verified, not claimed

ID	Risk	Coverage
ASI01	Agent Goal Hijack	**Partial** — prompt fencing is defense-in-depth, not proof; detection is the demoted classifier
ASI02	Tool Misuse & Exploitation	**Partial** — static policy rules
ASI03	Agent Identity & Privilege Abuse	**Strong** — signature-recovered addresses; refuses to fabricate identities

ID	Risk	Coverage
ASI04	Agentic Supply Chain	**Weak** — `pip-audit` blocking is good; no signed releases, no provenance attestations, no runtime image admission
ASI05	Unexpected Code Execution	**Not covered** — no sandboxed tool execution
ASI06	Memory & Context Poisoning	**Not covered**
ASI07	Insecure Inter-Agent Communication	**Not covered**
ASI08	Cascading Agent Failures	**Not covered**
ASI09	Human–Agent Trust Exploitation	**Partial** — approval workflow exists
ASI10	Rogue Agents	**Not covered** — no kill switch

Roughly 4 of 10 with meaningful coverage. The product narrative implies comprehensive agentic security. Closing that gap is a 6–12 month program, not a pass.

Other security findings

- **Prompt injection:** the supervisor still sends attacker-influenced metadata to an external model (`agents/supervisor_agent.py:82-116`). The LLM cannot move priority — correct — but it can produce recommendations that become approval proposals. **Treat all model output as untrusted and validate against an allowlisted action schema with target authorization.**
- **Model artifact:** the bundled classifier deserializes a **pickle** (`app/detection/classifier.py:89-99`). Pickle deserialization of a shipped artifact is a supply-chain vector.
- **Privacy / GDPR:** tombstones are necessary but not sufficient. Missing: data inventory, DPA and sub-processor list, retention enforcement evidence, DSAR workflows, lawful-basis controls, key destruction. Plus F-6 (unsalted correlation hash) creates a cross-customer purpose-limitation risk.
- **Compliance posture:** no SOC 2 Type II, no ISO 27001, no DPA. Table stakes for the enterprise buyer this is pitched at.
- **DR / recovery:** no disaster-recovery plan verified; **the code has never run in a cluster**, so recovery is untested by definition. F-4 means the *source* had no recovery either.

---

15. Performance & Scalability Audit

No seat could produce a benchmark, because **none exists.** Everything below is analytical.

Bottleneck	Mechanism	Ceiling
DLQ / queue drain	Serial per-tenant loop with a transaction each	O(tenants) per poll — 10k tenants ⇒ 10k transactions per poll
Per-tenant chain ordering	`prev_chain_hash` + `UNIQUE(tenant_id, prev_chain_hash)`	Intrinsically serial; caps per-tenant write throughput by design
Shared Postgres	Serves as queue, rate-limit coordinator, event store, evidence store *and* ledger sequencer	Single-instance contention under any real ingest
Worker plane	Threads inside API pods	Cannot scale independently of the API
Supervisor LLM	Synchronous external call, 20s timeout	Head-of-line blocking on the enrichment path
On-chain anchoring	Block finality	Adds seconds to any synchronous path; partly async via outbox
Dashboard	Polling, not streaming	Client-side load grows with incident count

The counter-intuitive finding: tenant *count*, not event volume, is the first thing to break. A design partner with 50 tenants will be fine; a white-label deployment with 5,000 will not, and the failure will look like unexplained latency rather than an error.

Path to scale, in the order the board recommends:

1. Shard queue ownership by tenant hash, or add a privileged audited scheduler path.
2. Move workers out of API pods into a separate plane.
3. **Measure** p95/p99 ingestion, policy decision, queue lag, evidence sealing, and cost per million events. Establish the Postgres ceiling empirically.
4. **Only then** consider Kafka/NATS. Codex was explicit: graduate to a broker only after proving the Postgres queue's ceiling — adopting one first is cargo cult.
5. Regional data planes with a global control plane; append-only object store plus compacted stream; batched Merkle commitments.

---

16. AI Capability Audit

The defining fact: the AI has been deliberately removed from the decision path — and this is simultaneously the best engineering decision in the codebase and the largest hole in the business.

Dimension	Assessment
Hallucination control	Excellent by construction — the model cannot influence priority or authority. Attacker-influenced text is structurally inert
Accuracy	AUC 0.763 cross-source over two folds. Unchanged across eight passes
Calibration	ECE 0.484 — confidence scores are effectively meaningless
Reasoning	Advisory only; recorded as `advisory_*`, never load-bearing
Tool use / planning / autonomy	Minimal by design. "Multi-agent SOC" is orchestration branding, not differentiated AI capability
Memory	No agent memory architecture; incident state is durable but not a learning substrate
Cost / latency	20s synchronous supervisor timeout on the enrichment path
Failure recovery	Graceful — pipeline completes with `advisory_available: false`. Correct
Multi-agent collaboration	Present as orchestration; no emergent capability
Adversarial robustness	**Not evaluated.** No red-team suite, no multilingual validation, no false-negative economics
Data flywheel	**None.** No customers ⇒ no telemetry ⇒ no training data ⇒ no improvement. This is the closed loop that must be broken

The board's unanimous judgment: removing the LLM from the control path was right and should not be reversed. But it means the AI-security product has almost no working AI in its own decisions, and **detection cannot improve in-house.** It requires consented design-partner telemetry — which requires customers — which requires a product people will deploy. Detection is downstream of GTM, not of engineering.

---

17. Hidden Opportunities & Patent-Worthy Ideas

Ignored markets

- **Consolidation-stranded buyers** — the clearest opening. CISOs who bought Lakera, Protect AI, Prompt Security or Astrix now answer to Check Point, Palo Alto, SentinelOne and Cisco roadmaps. They want neutrality, which an acquirer **structurally cannot offer.**
- **Regulated mid-market with high-consequence delegated actions** — fintech, healthcare, legal, insurance, BPO automation. They need auditability and cannot buy a $500k platform.
- **Auditors and assessors as a demand channel** rather than a buyer — if the verifier is free OSS and auditors ask for it, buyers adopt to satisfy the audit. This inverts a GTM problem the team cannot otherwise solve.

Patent-worthy

Ranked by the board's assessment of novelty and enforceability:

1. **Evidence-minimization compiler with selective disclosure** — compiling raw agent tool calls into a receipt containing only the fields necessary for a specific audit claim. Novel composition of proof systems with policy-guided schema extraction.
2. **Redaction-preserving hash chains** — lawful GDPR erasure that keeps inclusion proofs valid and reports `REDACTED` distinctly from tampering. Genuinely novel compliance primitive; already implemented.
3. **Identity-bound Merkle manifests** — relabel-proof, offline-verifiable agent evidence with per-tenant privacy via inclusion proofs (`merkle.py:67-82`). Already implemented.
4. **Cryptographic provenance of agent reasoning** *(Antigravity)* — sealing intermediate reasoning steps into the tree alongside the final action, proving an agent *intended* an action under valid policy. Directly addresses enterprise liability when models hallucinate.
5. **Delegation passports with cross-hop scope binding** — signed capability carrying purpose, scope, budget, expiry and approval chain across agent-to-agent hops.

The board's caveat, stated by Codex and endorsed: *"patents alone are not a moat, but an interoperable standard plus a reference SDK could be."* The defensibility is in adoption, not filing.

---

18. Investment Review

Would the named funds invest?

Fund	Verdict	Reasoning
Y Combinator	**Possibly, at pre-seed** — on the team, with a mandatory pivot	Strong technical founder signal; YC funds people at this stage. But the "generic AI SOC" framing would have to go on day one
Sequoia	**No**	Requires evidence of market pull. Zero customers, zero revenue, zero pilots
Andreessen Horowitz	**No**	Would want either a distribution insight or a genuine technical moat. The attestation wedge is real but is a feature today
Accel	**No**	Needs repeatable GTM motion; none exists
Lightspeed	**No**	Category consolidated; would ask why not just back Zenity/Noma
Benchmark	**No**	Concentrated bets on category-defining founders with early pull. No pull to point at

What a diligence team would find in the first week

1. No customers, no revenue, no pilots, no LOIs.
2. **No version control** — for a company selling tamper-evidence. This is the finding that ends most diligence conversations, independent of the code.
3. The core value path silently no-ops under retry (F-1).
4. The product's named capability — detection — does not work and cannot improve without customers.
5. The one differentiated asset (attestation crypto) is genuinely good and is roughly 3k LOC that a well-funded incumbent could reimplement in a quarter.

Investment score: 11 / 100

Down from 19. The board is explicit about why it *fell* rather than held: **a remediation pass that relocates a failure into the core value path is diligence-negative, not neutral.** It is evidence about the reliability of the remediation process itself — which is the thing an investor would be underwriting.

Strategic Options — weighted decision matrix (0-10 per criterion)

Option	Defensibility	Time To Revenue	Competitive Risk	Team Fit	Capital Need	Total
Continue as generic AI SOC	1	2	1	5	2	**11**
Vendor-neutral attestation layer	8	6	7	9	7	**37**
Own the open evidence standard (OSS verifier)	9	4	8	8	6	**35**
Acqui-hire into a platform	1	9	6	4	9	**29**

19. Business Model & Monetization

The board's first instruction: do not start with quote-only enterprise sales. With no customers and no reference logos, a quote-based motion has no entry point.

Recommended packaging

Tier	Offer	Price signal
Free / OSS	The standalone evidence verifier + developer SDK. **This is distribution, not revenue**	$0
Developer	Local agent testing, evidence receipts, capped volume	$0 → low
Team	Usage-based per verified agent-action receipt	Metered
Enterprise	Private deployment, retention, KMS/BYOK, SIEM/SOAR, policy simulation, compliance exports	Annual contract

Sell metered receipts, not seats. The unit of value is a verified agent action, and it is the only metric that grows with the customer's agent adoption rather than their headcount.

Growth loops and network effects

1. **Auditor loop (strongest).** Free OSS verifier → auditors request Sentinel-format evidence → buyers adopt to satisfy audits. Converts a GTM weakness into a demand channel.
2. **Standard loop.** Evidence passport becomes an interchange format → more producers → more consumers → the format becomes the requirement.
3. **Corpus loop.** Accumulated incident traces power policy-diff replay → switching cost rises with tenure. The only loop that also fixes detection.

Initial customer segment

Not general SOCs. **Regulated teams shipping agents with high-consequence delegated actions** — fintech, healthcare, legal, insurance, BPO automation — plus the consolidation-stranded cohort. 3–5 design partners, one paid pilot, in that order.

The honest outcome distribution

The board did not soften this. The most likely good outcome is **a tuck-in acquisition of the attestation primitives, or an acqui-hire**, not a standalone venture-scale company — unless all three conditions in §23 are met.

20. Risk Register

ID	Risk	Likelihood	Impact	Mitigation	Owner
R-1	Retry silently emits unanchored "COMPLETED" attestation	**High**	**Critical**	Rehydrate on resume + make `COMPLETED` unreachable when `is_anchored=false`	Backend lead
R-2	Stored XSS exploited via compromised enrichment provider	**Medium**	**Critical**	`textContent` + validated URLs + nonce CSP + taint test over all network fields	Frontend
R-3	Source loss recurs — no version control	**High**	**Critical**	git + remote + CI gate on green collect	Eng ops
R-4	Seventh relocation in the next pass	**High**	**Critical**	Independent reviewer breaks each fix before merge; extend mutation probes to every declared invariant	Eng lead
R-5	Detection never improves — no customers ⇒ no telemetry ⇒ no detection	**High**	**Critical**	Break the loop at GTM, not engineering: design partners first	Founder
R-6	Incumbent ships portable attestation and closes the wedge	**Medium**	**Critical**	Publish the format as an open standard early; speed is the only defense	Founder
R-7	Enterprise procurement fails on SOC2/SCIM/SAML/DPA	**High**	**High**	Sequence compliance behind first pilot, not before	Ops
R-8	Unaudited ECDSA primitive has a flaw	Low	**Critical**	External crypto audit before any paid pilot	Security
R-9	O(tenants) drain degrades a white-label deployment	**Medium**	**High**	Shard by tenant hash; benchmark before it matters	Backend
R-10	GDPR exposure via re-identifiable correlation hash	**Medium**	**High**	Tenant-keyed HMAC	Backend
R-11	Team continues optimizing engineering instead of pivoting	**High**	**Critical**	This report. Three boards have now said the same thing	Founder

R-4 and R-11 are the two the board weighted most heavily, and neither is a code defect. They are process risks: the remediation process keeps relocating failures, and the team keeps choosing engineering work over commercial work.

---

21. Launch Readiness Checklist

Can this product launch today? NO — unanimous.

#	Blocker	Severity	Why	Impact	Solution	Effort	Owner
1	Resume emits unanchored `COMPLETED`	**Critical**	Core promise silently no-ops on the retry path it was built for	Product's central claim is unreliable exactly under failure	Rehydrate artifacts; split `ATTESTED`/`ATTESTATION_UNAVAILABLE`; fault-injection tests at report + attest boundaries	2–3 d	Backend lead
2	Stored XSS in analyst console	**Critical**	Attacker-controlled intel reaches `innerHTML`; CSP permits inline script	Session/CSRF theft → privileged action in a security console	`textContent`, validated hex→fixed URL, nonce CSP, full-surface taint test	2–4 d	Frontend
3	No version control	**Critical**	Two load-bearing modules already lost to silent truncation	Unrecoverable source loss; fails diligence outright	git + remote + branch protection + CI gate on collect	1–2 d	Eng ops
4	Detection non-functional	**Critical**	AUC 0.763, ECE 0.48, unchanged in eight passes	Cannot make a detection claim to a security buyer	Reposition away from detection; start partner-telemetry program	1 d reposition / 6–12 mo data	Founder + ML
5	`_terminalise` bypasses the fence	**High**	Stale worker can mark a live incident `FAILED`	Corrupted state; violated single-writer invariant	Thread epoch; make worker-path failure APIs structurally require it; add mutation probe	1–2 d	Backend lead
6	Idempotency key never reaches gateway	**High**	Lease-steal window allows duplicate anchoring	Harmless on testnet; real on a paid chain	`assert_execution()` before publish; pass key; reconcile receipt	1–2 wk	Backend
7	No enforcement plane	**High**	Protect mode is `enforced: false`	Cannot be sold as a runtime control	SDK/proxy/MCP gateway with synchronous deny + receipt	2–4 mo	Backend

#	Blocker	Severity	Why	Impact	Solution	Effort	Owner
8	Manual instrumentation only	**High**	No OTel auto-instrumentation, no proxy, no eBPF	Blocks every pilot at day zero	OTel/OpenInference auto-instrumentation	6–10 wk	Backend
9	"MONITORING: LIVE" over a stale collector	**High**	UI asserts a capability the code does not have	Trust damage in the one product where trust is the product	Delete the stale monitor or make it authenticated, checkpointed, retrying	1 wk	Backend
10	Unsalted correlation hash	**High**	Low-entropy bodies re-identifiable	GDPR purpose-limitation exposure	Tenant-keyed HMAC	2–3 wk	Backend
11	No SOC2 / DPA / sub-processor list	**High**	Table stakes for the stated buyer	Procurement stops here	Sequence after first pilot	3–6 mo	Ops
12	Unaudited ECDSA primitive	**High**	Entire trust model rests on signature recovery	Silent forgery risk in the one differentiated asset	External crypto audit	4–6 wk	Security
13	O(tenants) queue drain	**Medium**	Tenant count is the first ceiling	Unexplained latency in white-label deployments	Shard by tenant hash; benchmark	3–6 wk	Backend
14	No SIEM/SOAR connectors	**Medium**	A SOC tool that doesn't feed the SOC's pane is shelfware	Blocks enterprise workflow fit	Splunk / MS Sentinel / Chronicle export	4–6 wk	Backend
15	Per-event testnet anchoring in the primary flow	**Medium**	Confuses the product; UI implies a deployment that doesn't exist	Credibility with compliance buyers	Batch anchoring to RFC 3161 / transparency log; drop testnet from the main path	2–4 wk	Backend
16	No SCIM/SAML/tenant management	**Medium**	Fails enterprise onboarding *and* offboarding	Procurement blocker at GA	SCIM + group-to-role mapping	6–10 wk	Backend

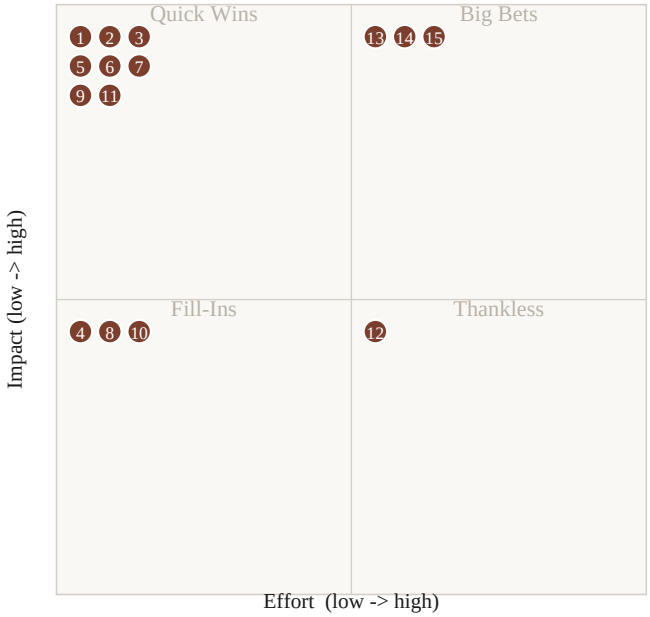
22. Prioritized Improvement Backlog

RICE Prioritisation — computed and sorted, not hand-ranked

#	Item	Reach	Impact	Conf.	Effort	RICE
1	Put repo under git + CI durability gate	10	3	1	0.5	**60.0**
2	Thread epoch through fail()/_terminalise + mutation probe	9	3	0.95	1	**25.6**
3	Reposition to evidence portability; drop detection claims	10	3	0.85	1	**25.5**
4	Delete or authenticate the stale Continuous Monitor	7	2	0.95	1	**13.3**
5	Split ATTESTED / ATTESTATION_UNAVAILABLE lifecycle states	9	3	0.9	2	**12.2**
6	Fix resume artifact hydration (F-1)	10	3	0.95	2.5	**11.4**
7	Close stored XSS + nonce CSP + full-surface taint test	8	3	0.95	3	**7.6**
8	Free OSS standalone evidence verifier	9	3	0.75	3	**6.8**
9	Narrow TERMINAL_ERRORS to origin-based classification	7	2	0.85	2	**6.0**
10	Tenant-keyed HMAC for correlation hashes	6	2	0.9	2	**5.4**
11	External crypto audit of ECDSA recovery	5	3	0.9	4	**3.4**
12	Pass idempotency key + assert_execution before publish	6	2	0.9	4	**2.7**

#	Item	Reach	Impact	Conf.	Effort	RICE
13	OTel / MCP / LangChain auto-instrumentation	10	3	0.8	9	**2.7**
14	Shard queue ownership by tenant hash	5	2	0.85	5	**1.7**
15	3-5 design partners on evidence portability	10	3	0.5	10	**1.5**
16	Enforceable protect mode via MCP gateway	9	3	0.6	14	**1.2**

Improvement Backlog — Impact vs Effort



1	Put repo under git + CI gate
2	Thread epoch through _terminalise
3	Reposition away from detection claims
4	Delete/authenticate stale monitor
5	Fix resume artifact hydration (F-1)
6	Split ATTESTED / UNAVAILABLE states
7	Close stored XSS + nonce CSP
8	Tenant-keyed HMAC correlation
9	Free OSS evidence verifier
10	Idempotency key to gateway
11	External crypto audit
12	Shard queue by tenant hash
13	OTel auto-instrumentation
14	3-5 design partners
15	Enforceable protect mode

The board's top 6, in order

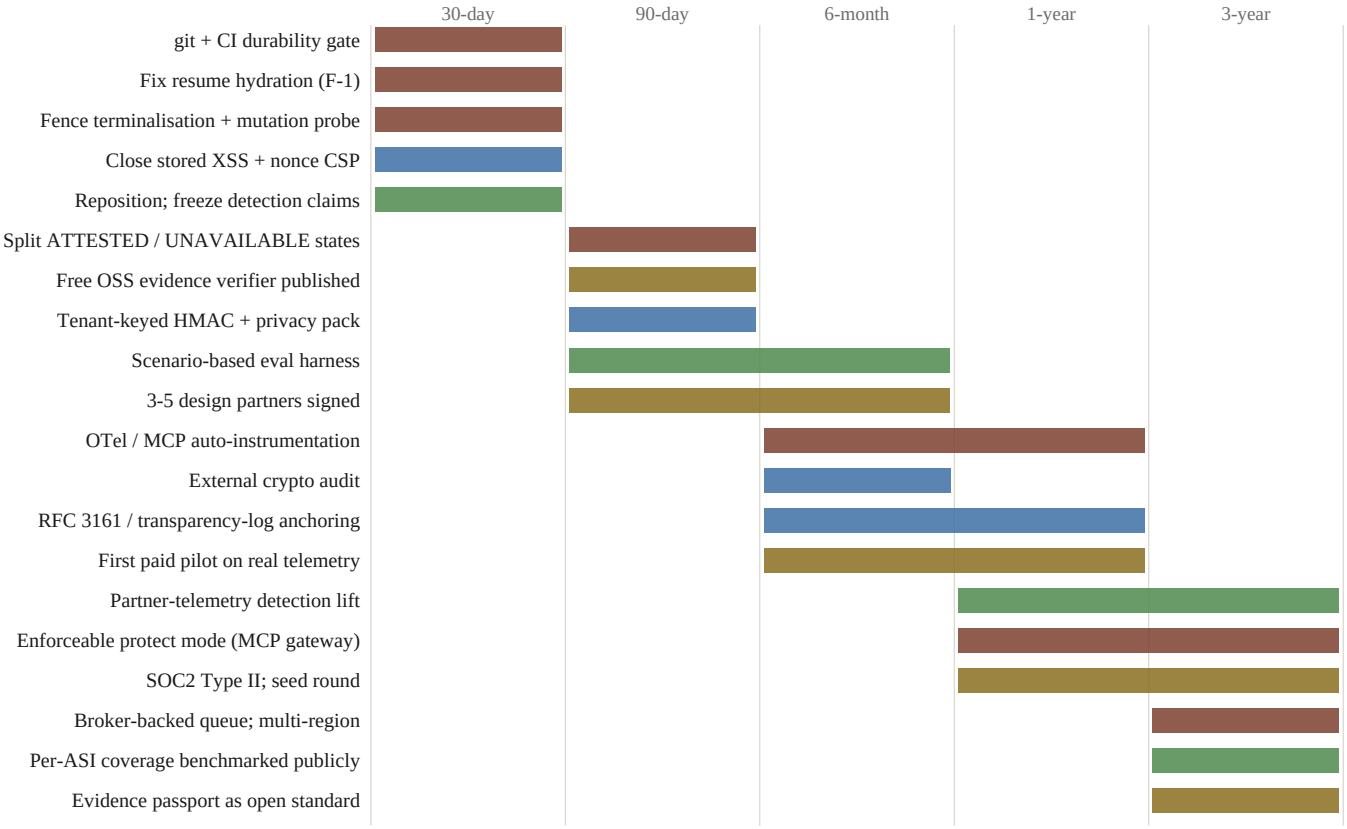
#	Action	Why	Effort	Impact
1	**Put the repo under git with a CI durability gate**	A tamper-evidence company lost a load-bearing module to silent truncation. Highest RICE in the entire backlog, and it is half a day	1–2 d	**H**
2	**Fix relocation #6** — rehydrate artifacts on resume; make `COMPLETED` unreachable when unanchored	The product's named value silently no-ops on the one path it was built to survive	2–3 d	**H**
3	**Thread** `epoch` **through** `fail()`**/**`_terminalise` + add the mutation probe	The C-2 fence is re-opened in the error path the docstring warns about, and the harness cannot see it	1–2 d	**H**
4	**Close the stored XSS** with a full-surface taint test, not another named-sink fix	Confirmed live XSS in an admin console; the "fixed" claim makes it more dangerous	2–4 d	**H**
5	**Reposition to evidence portability and land 3–5 design partners**	Every score that matters is commercial. Code is no longer the constraint	8–12 wk	**H**
6	**Ship the free OSS standalone verifier**	Converts the one differentiated asset into a distribution motion via the auditor loop	2–3 wk	**H**

Note the shape of this list. Items 1–4 total roughly **two engineer-weeks** and close every Critical technical finding. Item 5 is the actual company. The board's position is that items 1–4 should be finished *quickly and then stopped* — not expanded into a ninth remediation pass.

---

23. Multi-Year Product Roadmap

Six-horizon roadmap — Engineering, Security, AI, Business tracks



Eng	track: Eng
Sec	track: Sec
AI	track: AI
Biz	track: Biz

Horizon	Engineering	AI	Business	Hiring / Ops
30-day	git + CI gate; fix F-1, F-2, F-3; delete the stale monitor	Freeze detection claims; label advisory everywhere honestly	Write the evidence-portability ICP and a 5-partner target list	Hire a distributed-systems reviewer to break each fix *before* it ships
90-day	OTel auto-instrumentation; split lifecycle states; ship the OSS verifier	Scenario-based eval harness — not a new model	3 signed design partners; 1 paid pilot on real telemetry	First design-partner-facing SE
6-month	RFC 3161 / transparency-log anchoring; drop testnet from the main path	First partner-telemetry-trained classifier with **published calibration**	5 pilots; first ARR; published pricing	Founding GTM hire; crypto audit complete
1-year	Enforceable protect mode via MCP gateway — real deny + receipt	Closed-loop detection flywheel on partner data	Seed round on the evidence-portability wedge plus traction	Security-research hire; SOC 2 Type II underway

Horizon	Engineering	AI	Business	Hiring / Ops
3-year	Multi-region, broker-backed queue, horizontal autoscale under real load	Per-ASI detection coverage benchmarked publicly	Series A; own the consolidation-stranded cohort as beachhead	VP Eng; compliance lead
5-year	The neutral verification substrate every agent platform anchors to	Independent red-team-validated detection at incumbent parity	Category standard for portable agent-action evidence; regulatory reference implementation	Scaled org; partnerships with the platforms that consolidated

24. Final Council Consensus

Consensus scores

Dimension	Score	Rationale
Overall	**32**	Down 6. Engineering hygiene is real; the claims about it are not reliable, and nothing commercial moved
Engineering	50	Strong primitives undercut by a fresh relocation and three false "closed" claims
AI / ML	18	Unchanged in eight passes; the model is correctly outside the control path, which leaves little AI
UX	31	Authenticated console landed; adoption tax and trust-mismatched indicators remain
Architecture	50	Genuinely good primitives; rank-only resume and O(tenants) scheduling are architecture-level failures
Innovation	37	Identity-bound manifests and redaction-preserving chains are legitimately novel; the wedge is crowded
Security	42	Fail-closed verification is strong; live XSS and false-success lifecycle semantics are not
Scalability	29	Zero benchmarks, zero cluster runtime, serial per-tenant paths
Business	17	No customers, no distribution, no pricing validation, consolidated market
Investment-readiness	**11**	Down 8. A remediation that relocates failure into the core value path is diligence-negative
Launch readiness	**NOT READY**	4 Critical, 8 High blockers
Competitive moat	**NONE today**	One real wedge — portable, offline-verifiable, identity-bound evidence — which is a feature until it is a standard
Future potential	**Conditional**	Real, and contingent on three things, none of which is engineering
Risk assessment	**HIGH**	Process risk (relocation recurrence, engineering-over-commercial) exceeds technical risk

The final recommendation

Do not invest at seed or Series A. Do not launch. Do not run a paid pilot until the four Critical blockers close.

Do finish items 1–4 of the backlog — roughly two engineer-weeks — and then **stop doing remediation passes.** Three consecutive boards have now recommended the same repositioning and it has been deliberately declined three times. The board's answer to the brief's closing question is unambiguous:

> *Engineering remediation has reached diminishing marginal value. The binding constraint is now commercial. One more pass of elegant primitives around an unproven detector and zero customers would be the wrong move. More code is not the answer; a different company might be. — Claude Opus 4.8, Round 3*

What would have to be true for this to be a $1B+ company

Three conditions. **None of them is engineering hygiene.**

1. **Evidence portability becomes a buying requirement.** Enterprises stranded by the Lakera/Protect AI/Astrix consolidation demand vendor-neutral, offline-verifiable proof of what an agent did — and Sentinel's identity-bound Merkle attestation becomes the neutral standard incumbents anchor *to* rather than compete *with*.
2. **Detection reaches credibility via a data flywheel.** Partner telemetry lifts AUC from 0.763 to enterprise-grade with published calibration. "We don't detect, we attest" is a feature pitch, not a company.
3. **The adoption tax hits near zero.** OTel/eBPF auto-instrumentation replaces the manual SDK, and protect mode becomes genuinely enforceable.

If all three land, Sentinel is the SPIFFE or the transparency log of the agent era. **Today none are true.**

---

25. Actionable Next Steps

This week — 1) `git init`, push to a remote, enable branch protection, add a CI gate that fails on collect errors. 2) Fix F-1: rehydrate artifacts on resume *and* make `COMPLETED` structurally unreachable when `is_anchored=false`. 3) Fix F-2: thread `epoch` through `fail()`/`_terminalise` and add the mutation probe that would have caught it.

Next two weeks — 4) Close F-3 with a taint test over *every* network-derived field, not another named-sink patch. 5) Delete or authenticate the stale `ContinuousMonitor`, and remove the "MONITORING: LIVE" indicator until it is true. 6) Rewrite the README and pitch around evidence portability; delete every detection efficacy claim.

Next 90 days — 7) Publish the standalone verifier as free OSS. 8) Sign 3–5 design partners in regulated agent workflows. 9) Instrument one real agent end-to-end and get one paid pilot.

The discipline the board asks for: before shipping any of the fixes above, have someone who did not write it try to break it. The relocation pattern has now recurred six times, and every recurrence shared one property — **the fix was verified by the person who believed it was already correct.**

---

26. References & Appendices

A. Transcript index

File	Round	Seat	Size
`transcript/r1_claude.md`	1	Claude Opus 4.8	17.4 KB
`transcript/r1_codex.md`	1	Codex GPT-5.6-terra	18.0 KB
`transcript/r1_antigravity.md`	1	Antigravity / Gemini 3.1 Pro	10.8 KB
`transcript/r2_claude.md`	2	Claude Opus 4.8	10.6 KB
`transcript/r2_codex.md`	2	Codex GPT-5.6-terra	15.7 KB
`transcript/r2_antigravity.md`	2	Antigravity / Gemini 3.1 Pro	8.9 KB
`transcript/r3_claude.md`	3	Claude Opus 4.8	10.4 KB
`transcript/r3_antigravity.md`	3	Antigravity / Gemini 3.1 Pro	7.2 KB
`transcript/r3_codex.ERROR.txt`	3	Codex — **quota exhausted**	0.6 KB
`transcript/run_summary.json`	—	Run telemetry	2.5 KB

B. Source documents

`council/brief.md` (external intelligence brief, §8.1 = v7/v8 delta) · `council/REMEDIATION_V7.md` · `council/REMEDIATION_V8.md` · `council/COUNCIL_REPORT.md` (Seventh Review, baseline) · `council/seats.py` · `council/council.py`

C. Method limitations — stated, not hidden

1. **The Codex seat filed no Round 3.** Its final scores are Round 2 revisions; it stated no OVERALL integer and filed no formal votes. Nothing has been imputed on its behalf.
2. **Antigravity filed a non-conformant Round 3** — scores without an OVERALL, and no vote block. Its verdict is quoted from prose.
3. **The Overall consensus of 32 is a derived mean**, not a third independent judgment. Only Claude stated an Overall (33).
4. **Two of three seats are interested parties.** Claude implemented every remediation pass including v8 and was auditing its own work; Antigravity is from the vendor whose model wrote much of the original code. Claude disclosed this and filed the most damaging finding against itself, which mitigates but does not eliminate the conflict.

5. **No seat could execute the test suite.** All 459-test and live-Postgres claims were verified by reading, not running.
6. **No seat could verify runtime behaviour** — no cluster has ever run this code, so all scalability, DR and concurrency findings are analytical.
7. **No customer, revenue, pilot or GTM signal exists to verify**, because none exists.

D. Reproducing this review

```
py council/council.py --rounds 3 --timeout 2400
py council/make_pdf.py
```

Transcripts are written to `council/transcript/` as each seat lands, so an interrupted run resumes rather than re-billing completed seats. Delete a seat's transcript file to force it to re-run.